Lab07

#cyber-security

1 - Script Inspection

We install / copy the script contents into a new script file called `install.sh`, whose contents we can inspect via the `cat` command:



From inspecting the contents we can see that running this shell script will do the following:

1. Print out that it is installing software
2. make a new `src` directory
3. create a new `run.sh` script file
4. add the contents `echo Hello` to the newly created file
5. move the shell script to the src directory
6. run the shell script from within the src directory

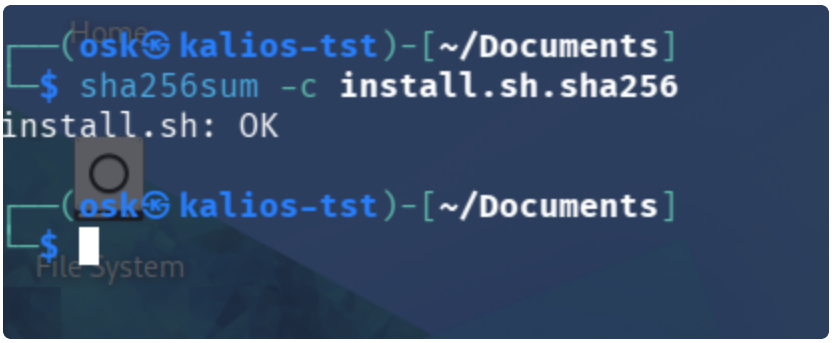
2 - Creating a Checksum of the Script Contents:

We can create a checksum of the script by using the SHA256 hashing algorithm via the command:
`sha256sum install.sh > install.sh.sha256` and we can verify the command worked via `cat`.



3 - Verify The File Integrity:

By running the command `sha256sum -c` on the newly created checksum we can check the integrity (the current directory is relevant when running this exact command).



4 - Generate GPG Key Pair:

As covered before we can generate an RSA key pair using `gpg --full-generate-key`, we will utilize the keys we already generated previously however.

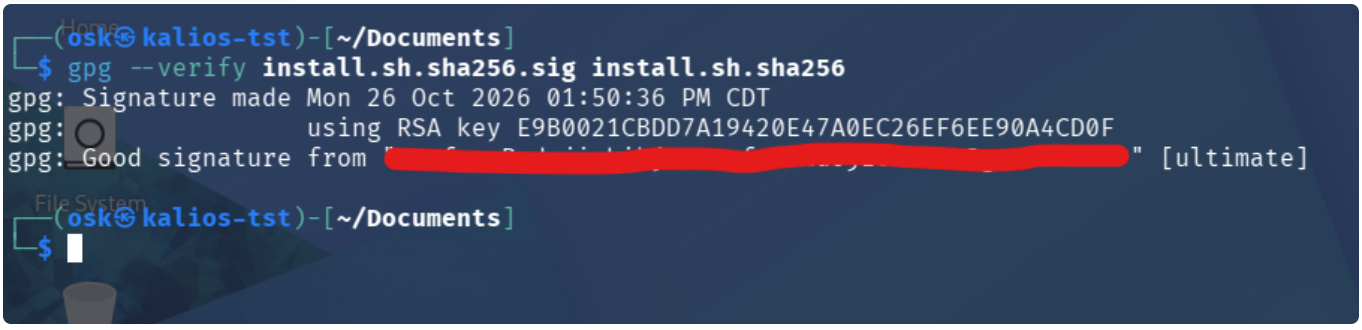
5 - Signing the Checksum File:

We can sign the checksum via our private key by running the command: `gpg --detach-sign install.sh.sha256`



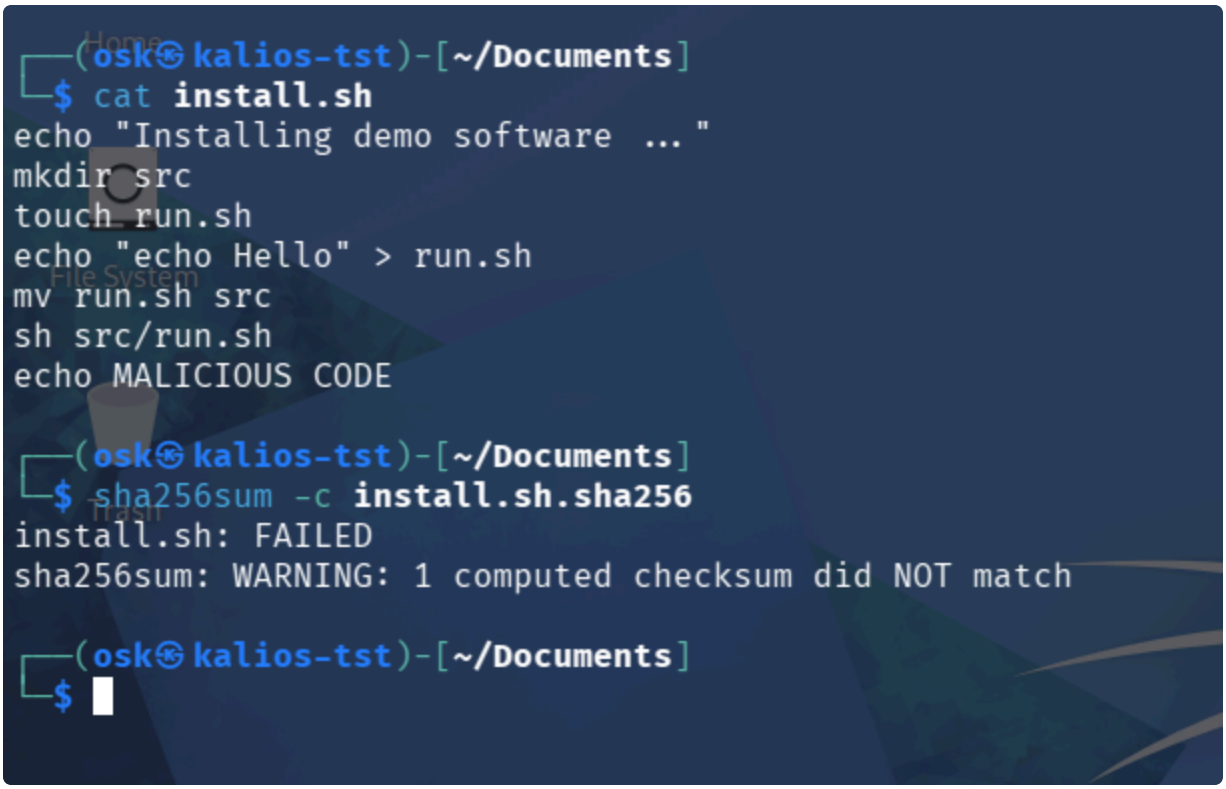
6 - Verifying The Signed Checksum:

We can verify the validity of the signed checksum via `gpg --verify install.sh.sha256.sig install.sh.sha256`



7 - Simulating a Tempering Attack:

We simulate a tempering attack by appending some arbitrary script content to the original file: `echo "echo 'MALICIOUS CODE EXECUTED'" >> install.sh`. Then we can re-run the verification and see the results.



As we can see the integrity check failed.

Closing Thoughts:

1. Why should you never execute scripts without inspection? : Due to potential malicious code within it
2. What does SHA256 guarantee? : SHA256 guarantees integrity, not authenticity
3. What does GPG guarantee? - GPG guarantees trust/authenticity (something is real and coming from the real source) given the public key is trusted and fingerprint is sourced from a trusted channel
4. Can SHA256 prove the author of a file? - No, it can only prove if the contents of something have been tempered with
5. Why is signing the checksum important? - If a given checksum has been checked, signing it provides trust - authenticity. Meaning that swapping the script with its checksum is not possible unless the attacker possesses the private key as well.
6. What happened after the script was modified? - The checksum changed and there was no match with the original checksum.